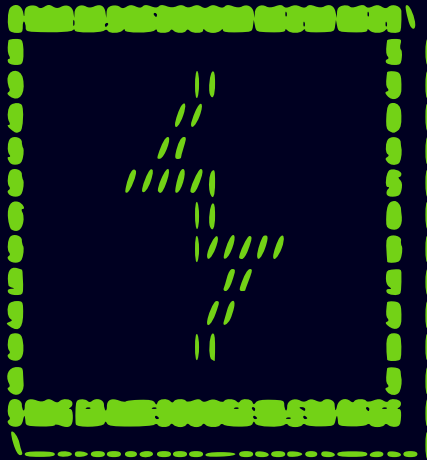


root@Chaos



- [1] Binaries Payloads
 - [2] Web Payloads
 - [3] Scripting Payloads
 - [4] Shellcode
- [*] BurpSuite payloads
- with Chaos 



Part 1

Contents

2		Part 1
2		Beginners Guide to Burp Suite Payloads
3		Simple List
5		Configuring Payloads and Starting the Attack
7		Runtime File
9		Case Modification
11		Configuring Payloads and Starting the Attack
13		Numbers
14		Intercepting and Selecting Payload Positions
15		Configuring Payloads and Starting the Attack
17		Brute Forcer
17		Intercepting and Selecting Payload Positions
18		Configuring Payloads and Starting the Attack



Part 1

Beginners Guide to Burp Suite Payloads

با درود به دوستان! امروز در مورد انواع **Payload** در **Burp Suite** صحبت خواهیم کرد **Burp Suite** یک برنامه کاربردی است که برای تست امنیت برنامه‌های تحت وب (**Web application security**) استفاده می‌شود. ابزارهای متنوع آن به طور یکپارچه با هم کار می‌کنند تا از کل فرآیند تست، از نقشه‌برداری اولیه و تحلیل سطح حمله یک برنامه گرفته، تا پیدا کردن و بهره‌برداری از آسیب‌پذیری‌های امنیتی، پشتیبانی کنند. این ابزار با زبان **JAVA** نوشته شده و توسط **PortSwigger Security** توسعه یافته است. ما قصد داریم از قابلیت **Intruder** در **Burp Suite** استفاده کنیم که برای حملات **brute force** علیه برنامه‌های تحت وب به کار می‌رود. در **Intruder 18** نوع **Payload** وجود دارد، از جمله:

- **Simple list**
- **Runtime File**
- **Case Modification**
- **Numbers**
- **Character substitution**
- **Custom iterator**
- **Recursive grep**
- **Illegal Unicode**
- **Character blocks**
- **Dates**
- **Brute Forcer**
- **Null Payloads**
- **Character frober**
- **Bit Flipper**
- **Username generator**
- **ECB block shuffler**
- **Extension Generated**
- **Copy other payload**



Simple List

سلام دوستان! اینجا یکی از ساده‌ترین انواع **Payload** را بررسی می‌کنیم که به شما امکان پیکربندی یک دیکشنری کوتاه از رشته‌ها را به عنوان **Payload** می‌دهد.

مراحل کار

1. ابتدا درخواست صفحه لاگین در **DVWA LAB** را **intercept** می‌کنیم. یک نام کاربری و رمز عبور تصادفی وارد کرده و روی **login** کلیک می‌کنیم **Burp Suite**. درخواست را ثبت خواهد کرد.

2. درخواست ثبت شده را با کلیک روی تب **Action** و انتخاب گزینه مناسب به **Intruder** ارسال می‌کنیم.

3. به تب **Intruder** رفته و بخش **Positions** را انتخاب می‌کنیم. مشاهده می‌کنید که نام کاربری و رمز عبور به صورت خودکار **highlight** شده‌اند.

4. برای تعیین دقیق موقعیت حمله:

- ابتدا دکمه **Clear** در سمت راست پنجره را فشار دهید.

- سپس فیلدهای مورد نظر برای حمله (نام کاربری و رمز عبور) را انتخاب کرده و دکمه **Add** را کلیک کنید.

5. نوع حمله (**Attack type**) را **Cluster Bomb** انتخاب می‌کنیم.

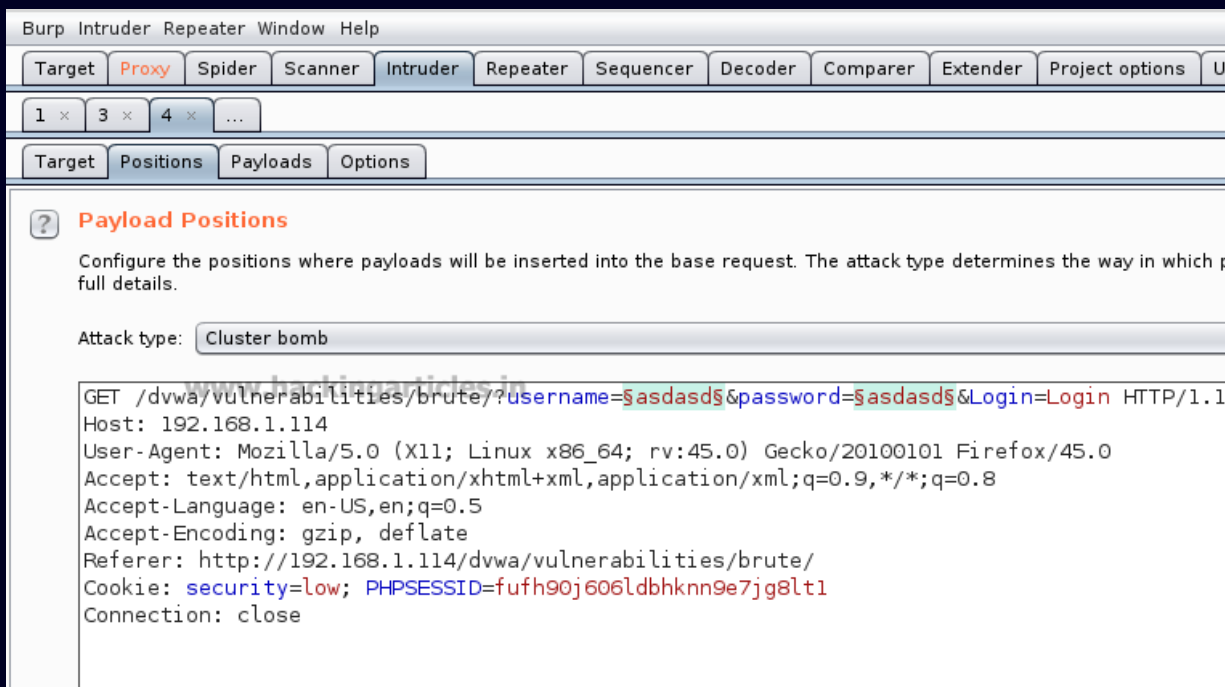
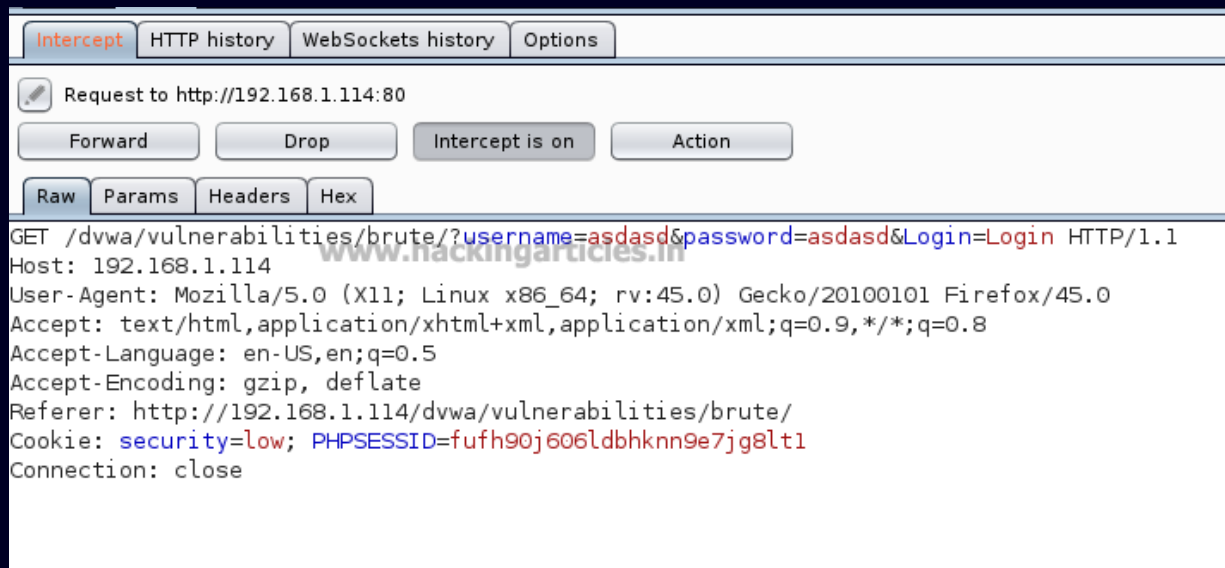
6. همانطور که در تصویر زیر مشاهده می‌کنید، ما دو پارامتر (نام کاربری و رمز عبور) انتخاب کرده‌ایم که به این معنی است به دو فایل دیکشنری نیاز داریم:

- یکی برای نام کاربری

- دیگری برای رمز عبور

این روش به ما امکان می‌دهد حمله **brute-force** را به صورت کارآمد و هدفمند انجام دهیم.





Configuring Payloads and Starting the Attack

حالا، به تب **Payloads** بروید و عدد **1** را از **Payload set** انتخاب کنید (این عدد **1** نشان‌دهنده فایل اول برای انتخاب است). سپس روی دکمه **Load** کلیک کنید و فایل دیکشنری مربوط به نام کاربری را انتخاب نمایید.

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the set, and each payload type can be customized in different ways.

Payload set: 1 Payload count: 5
 Payload type: Simple list Request count: 10

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste: abc
 Load ...: 1234
 Remove: admin
 Clear: ignite@123
 msfadmin

Add: Enter a new item
 Add from list ...

اکنون عدد **2** را در **Payload set** انتخاب کرده و مجدداً فایل دیکشنری مربوط به رمز عبور را وارد کنید. از منوی **Intruder** گزینه **Start Attack** را همانطور که در تصویر نشان داده شده است، انتخاب کنید.

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the set, and each payload type can be customized in different ways.

Payload set: 2 Payload count: 7
 Payload type: Simple list Request count: 35

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste: abc
 Load ...: 12345
 Remove: admin
 Clear: ignite@123
 msfadmin
 password
 61778902

Add: Enter a new item
 Add from list ...



حالا **Burp Suite** کار خود را انجام می‌دهد، ترکیب معتبر نام کاربری و رمز عبور را مطابقت داده و رمز عبور و نام کاربری صحیح را به شما می‌دهد. به محض اینکه مقدار صحیح را پیدا کند، مقدار **length** (طول) را تغییر می‌دهد همانطور که نشان داده شده است.

Attack Save Columns							
Results Target Positions Payloads Options							
Filter: Showing all items							
Request	Payload1	Payload2	Status	Error	Timeout	Length	Comment
22	1234	msfadmin	200			5501	
23	admin	msfadmin	200			5501	
24	ignite@123	msfadmin	200			5501	
25	msfadmin	msfadmin	200			5501	
26	abc	password	200			5501	
27	1234	password	200			5501	
28	admin	password	200			5560	
29	ignite@123	password	200			5501	
30	msfadmin	password	200			5501	
31	abc	61778902	200			5501	
32	1234	61778902	200			5501	
33	admin	61778902	200			5501	
34	ignite@123	61778902	200			5501	
35	msfadmin	61778902	200			5501	

Request	Response
Raw Params Headers Hex	
<pre>GET /dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1 Host: 192.168.1.114 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Accept-Encoding: gzip, deflate Referer: http://192.168.1.114/dvwa/vulnerabilities/brute/ Cookie: security=low; PHPSESSID=fufh90i606ldbkmn9e7ia8lt1</pre>	

برای تأیید تطابق نام کاربری و رمز عبور، مقادیر مطابقت‌یافته را در صفحه لاگین **DVWA LAB** وارد می‌کنیم. پیامی با عنوان **"Welcome to the password protected area admin"** مشاهده خواهیم کرد که نشان‌دهنده موفقیت ما در حمله **payload** از نوع **simple list** است.



[Home](#)
[Instructions](#)
[Setup / Reset DB](#)
[Brute Force](#)
[Command Injection](#)
[CSRF](#)
[File Inclusion](#)
[File Upload](#)
[Insecure CAPTCHA](#)
[SQL Injection](#)

Vulnerability: Brute Force

Login

Username:

Password:

Login

Welcome to the password protected area admin



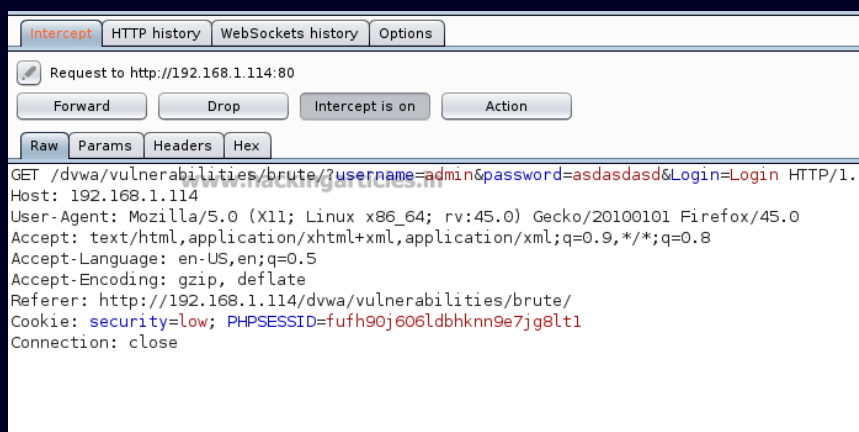


Runtime File

این نوع **payload** به شما امکان می‌دهد یک فایل را پیکربندی کنید که رشته‌های **payload** را در زمان اجرا می‌خواند. زمانی به این نوع **payload** نیاز داریم که به یک لیست بزرگ از **payload** ها نیاز داشته باشیم تا از نگهداری کل لیست در حافظه جلوگیری شود. این **payload** به شما اجازه می‌دهد لیست بزرگی از رشته‌ها را پیکربندی کنید که بر محدودیت نوع **payload** ساده غلبه می‌کند.

مراحل کار:

1. ابتدا درخواست صفحه لاگین در **DVWA LAB** را **intercept** کردیم، جایی که یک نام کاربری تصادفی و یک رمز عبور تصادفی وارد کرده‌ایم. سپس روی **login** کلیک می‌کنیم و **Burp Suite** درخواست صفحه لاگین را در تب **intercept** ثبت می‌کند.



2. درخواست ثبت شده را به **Intruder** ارسال کرده و مراحل زیر را دنبال می‌کنیم:

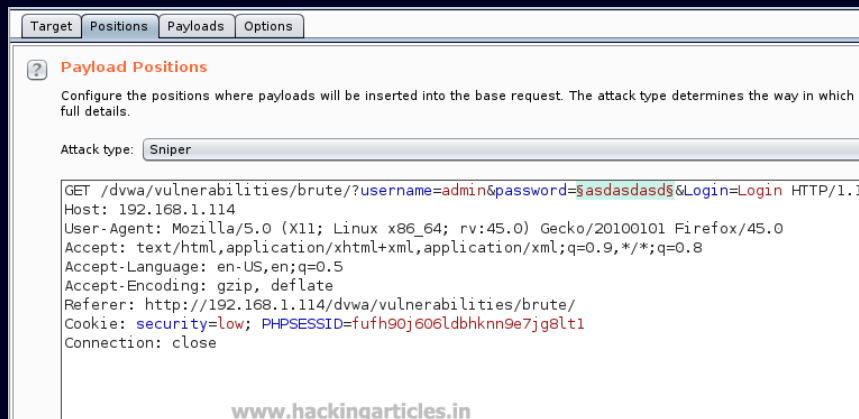
- به تب **Intruder** رفته و بخش **Positions** را انتخاب می‌کنیم.
- مشاهده می‌کنید که رمز عبور به صورت خودکار **highlight** شده است.

3. برای تعیین موقعیت حمله:

- دکمه **Clear** در سمت راست پنجره را فشار دهید.
- سپس فیلد مورد نظر برای حمله (یعنی فیلد رمز عبور) را انتخاب کرده و دکمه **Add** را کلیک کنید.

4. نوع حمله (**Attack type**) را انتخاب کنید احتمالاً **Sniper** یا **Cluster Bomb** بسته به سناریو.



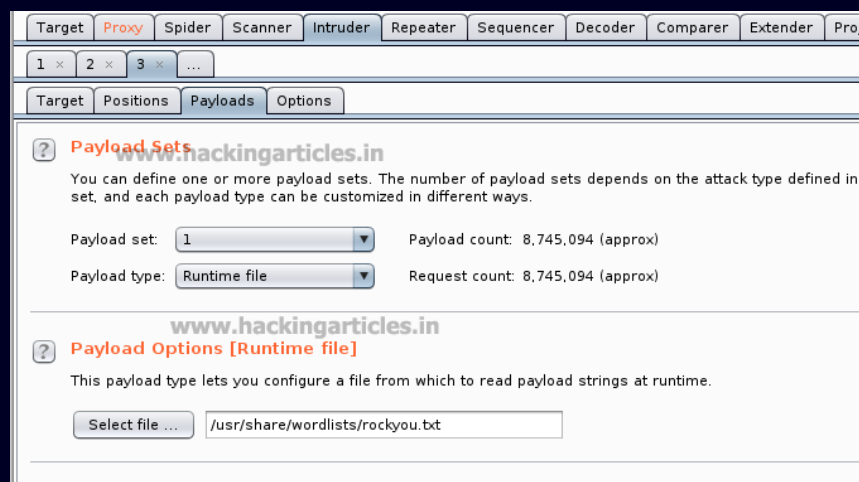


5. همانطور که در تصویر زیر مشاهده می‌کنید، ما فقط رمز عبور را انتخاب کرده‌ایم، که به این معنی است فقط به یک فایل دیکشنری برای رمز عبور نیاز داریم.

6. سپس **Payload type** را به صورت **Runtime File** انتخاب کرده و مسیر دیکشنری را در بخش **Payload Options** وارد می‌کنیم

مثال **/usr/share/wordlists/rockyou.txt** که بزرگترین دیکشنری در **Kali Linux** است

7. از منوی **Intruder** گزینه **Start Attack** را انتخاب کنید.



8. حالا **Burp Suite** کار خود را انجام می‌دهد و رمز عبور صحیح را پیدا می‌کند. به محض یافتن مقدار صحیح، مقدار **length** (طول) تغییر می‌کند، همانطور که نشان داده شده است.



Attack Save Columns						
Results Target Positions Payloads Options						
Filter: Showing all items						
Request	Payload	Status	Error	Timeout	Length	Comment
4	password	200	☐	☐	5560	
20	password	200	☐	☐	5560	
0		200	☐	☐	5501	
1	123456	200	☐	☐	5501	
2	12345	200	☐	☐	5501	
3	123456789	200	☐	☐	5501	
5	iloveyou	200	☐	☐	5501	
6	princess	200	☐	☐	5501	
7	1234567	200	☐	☐	5501	
8	rockyou	200	☐	☐	5501	
9	12345678	200	☐	☐	5501	
10	abc123	200	☐	☐	5501	
11	nicole	200	☐	☐	5501	
12	daniel	200	☐	☐	5501	
13	babymid	200	☐	☐	5501	

Request Response	
Raw Params Headers Hex	
GET /dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1 Host: 192.168.1.114 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Accept-Encoding: gzip, deflate Referer: http://192.168.1.114/dvwa/vulnerabilities/brute/ Cookie: security=low: PHPSESSID=fufh90i606ldbhknn9e7ia8lt1	
? < + > Type a search term	

مزیت اصلی :

این روش برای حملات **brute-force** با لیست‌های بسیار بزرگ ایده‌آل است، زیرا **payload** ها را **directly** از فایل خوانده و حافظه سیستم را اشباع نمی‌کند .

Case Modification

این نوع پیلود به شما امکان می‌دهد یک لیست از رشته‌ها را پیکربندی کرده و تغییرات حالتی مختلفی به هر آیتم در لیست اعمال کنید. این قابلیت در حملات حدس زدن رمز عبور برای تولید تغییرات حالتی مختلف بر اساس کلمات دیکشنری مفید است .

قوانین تغییر حالت قابل انتخاب عبارت‌اند از :

- **No change** آیتمان بدون تغییر استفاده می‌شود .
- **To lower case** تمام حروف آیتمان به حروف کوچک تبدیل می‌شوند .
- **To upper case** تمام حروف آیتمان به حروف بزرگ تبدیل می‌شوند .
- **To Proper name** حرف اول آیتمان به بزرگ تبدیل شده و باقی حروف به کوچک تبدیل می‌شوند .
- **To Proper Name** حرف اول آیتمان به بزرگ تبدیل شده و باقی حروف تغییر نمی‌کنند .

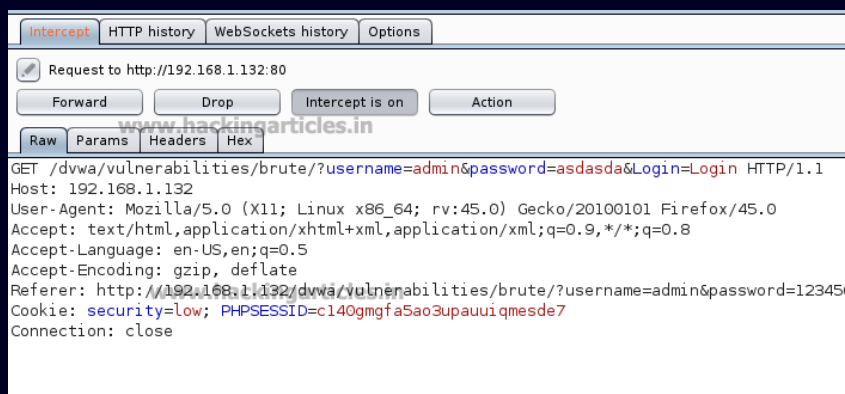


برای مثال، اگر همه گزینه‌های تغییر را انتخاب کنیم، آیتمان **"Raj Chandel"** پیلوهای زیر را تولید می‌کند:

- **Raj Chandel** بدون تغییر
- **raj chandel** حروف کوچک
- **RAJ CHANDEL** حروف بزرگ
- **Raj chandel** حرف اول بزرگ، باقی کوچک
- **Raj Chandel** حرف اول بزرگ، باقی بدون تغییر

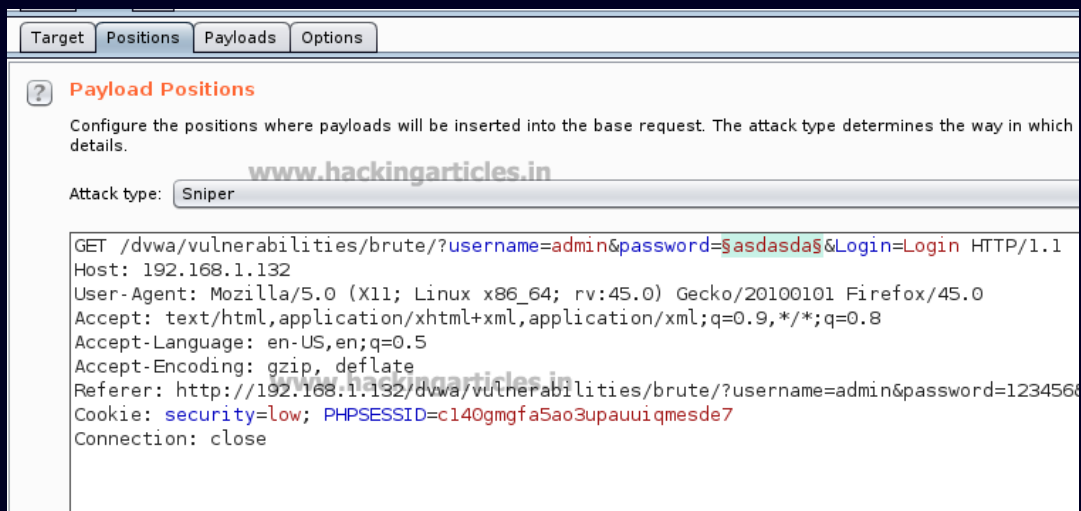
مراحل اجرا:

1. ابتدا درخواست صفحه لاگین در **DVWA LAB** را **intercept** می‌کنیم. یک نام کاربری و رمز عبور تصادفی وارد کرده و روی **login** کلیک می‌کنیم **Burp Suite**. درخواست را در تب **intercept** ثبت می‌کند.



2. درخواست ثبت شده را با راست کلیک و انتخاب گزینه **Send to Intruder** یا فشردن کلیدهای **Ctrl + I** به **Intruder** ارسال می‌کنیم.
3. به تب **Intruder** رفته و بخش **Positions** را انتخاب می‌کنیم. مشاهده می‌کنید که رمز عبور به صورت خودکار **highlight** شده است.





4. برای تعیین موقعیت حمله :

○ دکمه **Clear** در سمت راست پنجره را فشار دهید .

○ فیلد مورد نظر برای حمله (یعنی فیلد رمز عبور) را انتخاب کرده و دکمه **Add** را کلیک کنید .

5. نوع حمله (**Attack type**) را انتخاب کنید (مثلاً **Sniper**).

6. همانطور که در تصویر زیر مشاهده می‌کنید، ما فقط رمز عبور را انتخاب کرده‌ایم، که به این معنی است فقط به

یک فایل دیکشنری برای رمز عبور نیاز داریم .

این روش به شما کمک می‌کند تا با تولید خودکار تغییرات حالتی، شانس موفقیت در حملات **brute-force** را افزایش دهید!

Configuring Payloads and Starting the Attack

سپس نوع **Payload** را به صورت **Case Modification** انتخاب کنید. ما در بخش **Payload**

Options گزینه‌های **No change** و **To lower case** را انتخاب کرده‌ایم، همانطور که در تصویر

نشان داده شده است. یک دیکشنری پیش‌فرض رمز عبور نیز از طریق گزینه **Add from list** در بخش

Payload Options اضافه کرده‌ایم. در نهایت، از منوی **Intruder** گزینه **Start Attack** را

همانطور که در تصویر نشان داده شده است، انتخاب کنید .



Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Each payload type can be customized in different ways.

Payload set: Payload count: 5,820 (approx)

Payload type: Request count: 5,820 (approx)

Payload Options [Case modification]

This payload type lets you configure a list of strings and apply various case modifications to each item.

Case modifications

- ☒ No change
- ☒ To lower case
- ☐ To upper case
- ☐ To Propername
- ☐ To ProperName

Items (3424)

Enter a new item

Items list:

```

!@#%$
!@#%$^
!@#%$^&*
!@#%$^&*
!root
$SRV
$secure$
*3noguru
@#%$^&
A.M.I
  
```

حالا **Burp Suite** کار خود را انجام می‌دهد، رمز عبور را مطابقت داده و رمز عبور صحیح را به شما می‌دهد. به محض اینکه مقدار صحیح را پیدا کند، مقدار **length** (طول) تغییر می‌کند، همانطور که نشان داده شده است.

Results Target Positions Payloads Options

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
1324	parker	200			5501	
1325	Passwor	200			5501	
1326	passwor	200			5501	
1327	Password	200			5501	
1328	password	200			5563	
1329	Patches	200			5501	
1330	patches	200			5501	
1331	Patrick	200			5501	
1332	patrick	200			5501	
1333	Peaches	200			5501	
1334	peaches	200			5501	
1335	Peanut	200			5501	
1336	peanut	200			5501	
1337	Pebbles	200			5501	
1338	pebbles	200			5501	

Request Response

Raw Params Headers Hex

GET /dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1
 Host: 192.168.1.132
 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0
 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 Accept-Language: en-US,en;q=0.5
 Accept-Encoding: gzip, deflate
 Referer: http://192.168.1.132/dvwa/vulnerabilities/brute/?username=admin&password=1234
 Cookie: security=low; PHPSESSID=c140amfa5ao3upauuimesde7

Type a search term



Numbers

Payload نوع عددی (Numbers)

این نوع پیلود، مقادیر عددی را در یک محدوده مشخص و با فرمت تعریف شده تولید می‌کند.

گزینه‌های قابل پیکربندی در این پیلود عبارت‌اند از:

1. محدوده اعداد: (Number range)

- **Type** نوع: تعیین می‌کند که اعداد به صورت **sequential** ترتیبی یا **random** تصادفی تولید شوند.
- **From** از: اگر اعداد به صورت ترتیبی تولید شوند، این گزینه مقدار شروع را مشخص می‌کند.
- **To** تا: اگر اعداد به صورت ترتیبی تولید شوند، این گزینه مقدار پایان را مشخص می‌کند. در حالت تصادفی، این مقدار به عنوان بالاترین عدد ممکن برای تولید تعیین می‌شود.
- **Step** گام: این گزینه مخصوص تولید ترتیبی است و میزان افزایش در اعداد متوالی را مشخص می‌کند.
- **How many** تعداد: این گزینه فقط در حالت تصادفی قابل استفاده است و تعداد پیلودهایی که باید تولید شوند را مشخص می‌کند.

مثال کاربردی:

فرض کنید می‌خواهید یک حمله **brute-force** روی یک پارامتر عددی (مثل **id=1**) انجام دهید:

- **Sequential** نوع:
- **From: 1**
- **To: 1000**
- **Step: 1**

در این حالت، **Burp Suite** اعداد ۱ تا ۱۰۰۰ را به ترتیب تولید کرده و ارسال می‌کند.

اگر حالت **Random** انتخاب شود و **How many** روی ۵۰ تنظیم شود، ۵۰ عدد تصادفی بین محدوده تعیین شده تولید می‌شود.

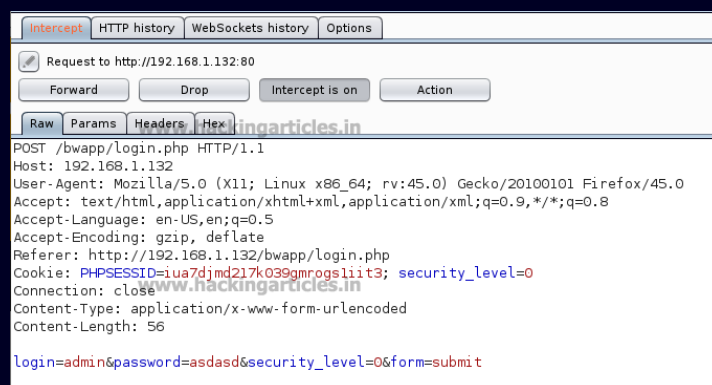


کاربردها:

- تست پارامترهای عددی مثل ID کاربر، شماره تراکنش .
- دور زدن محدودیت‌های ورودی با فرمت‌های عددی .
- تولید خودکار مقادیر برای حملات **brute-force** کارآمد .

Intercepting and Selecting Payload Positions

ابتدا درخواست صفحه لاگین در **Bwapp Lab** را **intercept** می‌کنیم، جایی که یک نام کاربری تصادفی و یک رمز عبور تصادفی وارد کرده‌ایم. سپس روی **login** کلیک می‌کنیم. **Burp Suite** درخواست صفحه لاگین را ثبت خواهد کرد .



درخواست ثبت شده را به **Intruder** ارسال کرده و مراحل زیر را دنبال می‌کنیم:

- به تب **Intruder** رفته و بخش **Positions** را انتخاب می‌کنیم .
- مشاهده می‌کنید که رمز عبور به صورت خودکار **highlight** شده است .

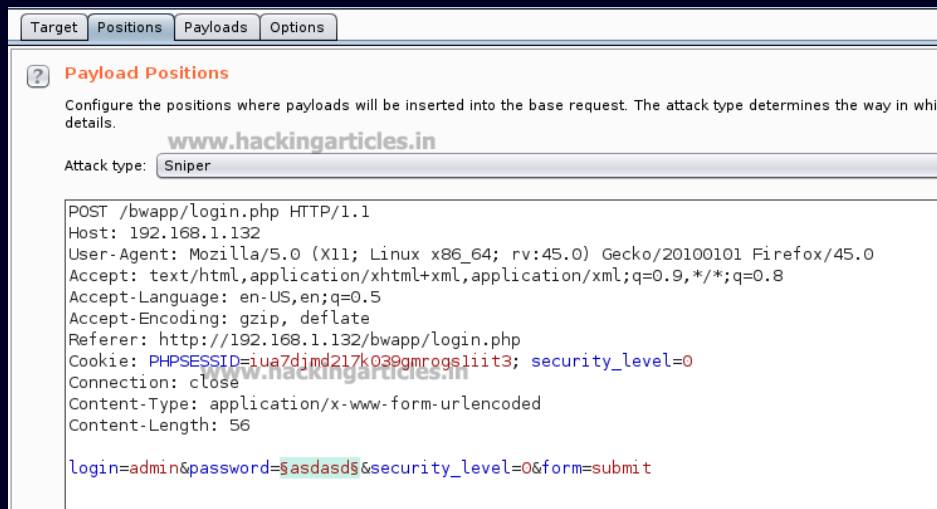
برای تعیین موقعیت حمله:

- دکمه **Clear** در سمت راست پنجره را فشار دهید .
- سپس فیلد مورد نظر برای حمله (یعنی فیلد رمز عبور) را انتخاب کرده و دکمه **Add** را کلیک کنید .

نوع حمله (**Attack type**) را انتخاب کنید مثلاً **Sniper**

همانطور که در تصویر زیر مشاهده می‌کنید، ما فقط رمز عبور را انتخاب کرده‌ایم، که به این معنی است فقط به یک فایل دیکشنری برای رمز عبور نیاز داریم .





Payload Positions

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which details.

Attack type: **Sniper**

```
POST /bwapp/login.php HTTP/1.1
Host: 192.168.1.132
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.132/bwapp/login.php
Cookie: PHPSESSID=iua7dmd217k039gmrogsliit3; security_level=0
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 56

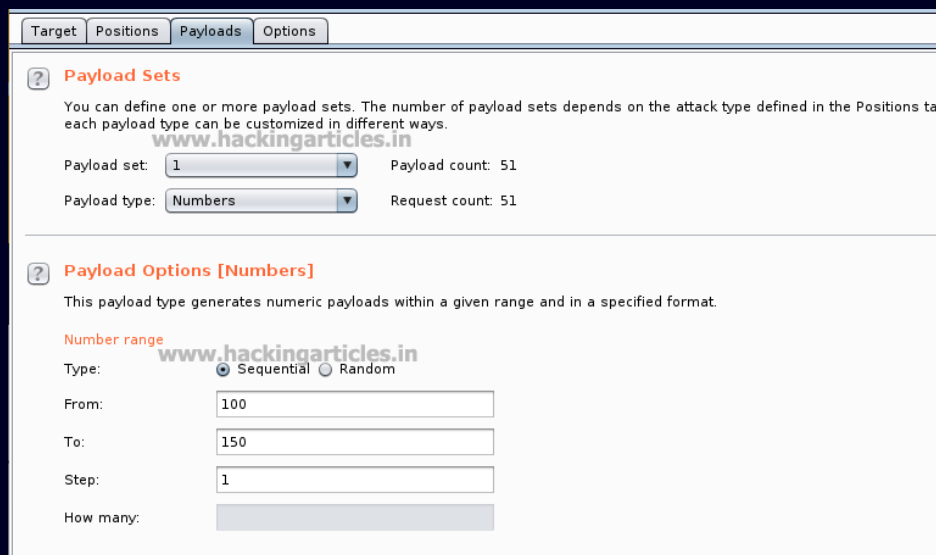
login=admin&password=$asdasds&security_level=0&form=submit
```

نکته :

این روش برای حملات **brute-force** روی رمز عبور ایده آل است، به خصوص زمانی که از یک دیکشنری قوی مثل **rockyou.txt** استفاده می کنید .

Configuring Payloads and Starting the Attack

سپس نوع **Payload** را به صورت **Numbers** انتخاب کنید، جایی که محدوده اعداد را از ۱۰۰ تا ۱۵۰ تعیین کرده ایم و گام **(step)** را روی ۱ تنظیم کرده ایم، همانطور که در تصویر نشان داده شده است. از منوی **Intruder** گزینه **Start Attack** را انتخاب کنید .



Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Each payload type can be customized in different ways.

Payload set: **1** Payload count: 51

Payload type: **Numbers** Request count: 51

Payload Options [Numbers]

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: ☒ Sequential ☐ Random

From: **100**

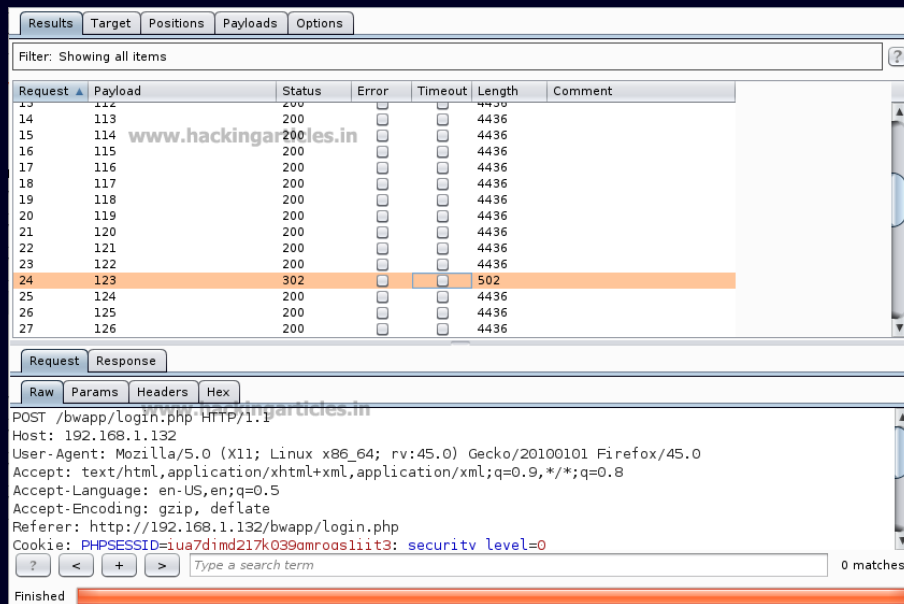
To: **150**

Step: **1**

How many:

حالا **Burp Suite** کار خود را انجام می دهد، رمز عبور را مطابقت داده و رمز عبور صحیح را به شما می دهد. به محض اینکه مقدار صحیح را پیدا کند، مقدار **length** (طول) تغییر می کند، همانطور که نشان داده شده است .





از آنجایی که رمز عبور با یک عدد که در محدوده عددی داده شده قرار دارد، مطابقت می‌کند. برای تأیید تطابق رمز عبور، آن را در صفحه لاگین **Bwapp LAB** وارد می‌کنیم که ما را با موفقیت به آزمایشگاه **Bwapp** وارد می‌کند. این موضوع موفقیت ما در حمله را نشان می‌دهد.



Brute Forcer

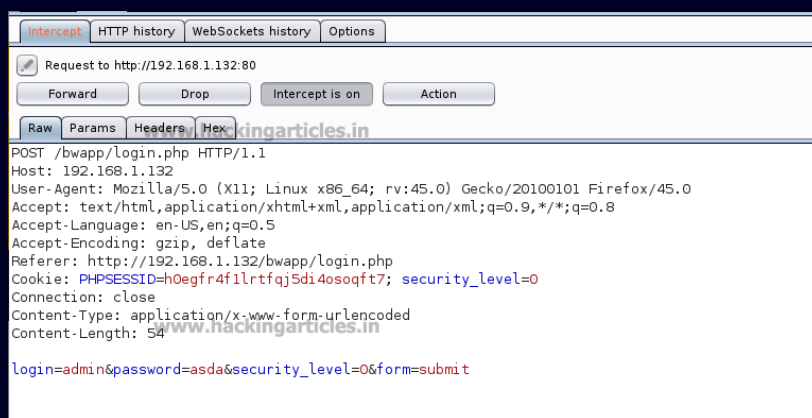
این نوع پیلود، ترکیباتی از کاراکترها را با طول مشخص تولید می‌کند که شامل تمام جایگشت‌های ممکن از لیست کاراکترهای داده شده است.

گزینه‌های قابل پیکربندی:

- **Character set** مجموعه کاراکترها: کاراکترهایی که باید در پیلودها استفاده شوند. توجه کنید که تعداد کل پیلودها به صورت نمایی با اندازه این مجموعه افزایش می‌یابد.
- **Min length** حداقل طول: طول کوتاه‌ترین پیلود.
- **Max length** حداکثر طول: طول بلندترین پیلود.

Intercepting and Selecting Payload Positions

1. ابتدا درخواست صفحه لاگین در **Bwapp LAB** را **intercept** می‌کنیم. یک نام کاربری و رمز عبور تصادفی وارد کرده و روی **login** کلیک می‌کنیم **Burp Suite**. درخواست را ثبت می‌کند.
2. درخواست ثبت شده را به **Intruder** ارسال می‌کنیم.



3. به تب **Intruder** رفته و بخش **Positions** را انتخاب می‌کنیم. مشاهده می‌کنید که رمز عبور **highlight** شده است.

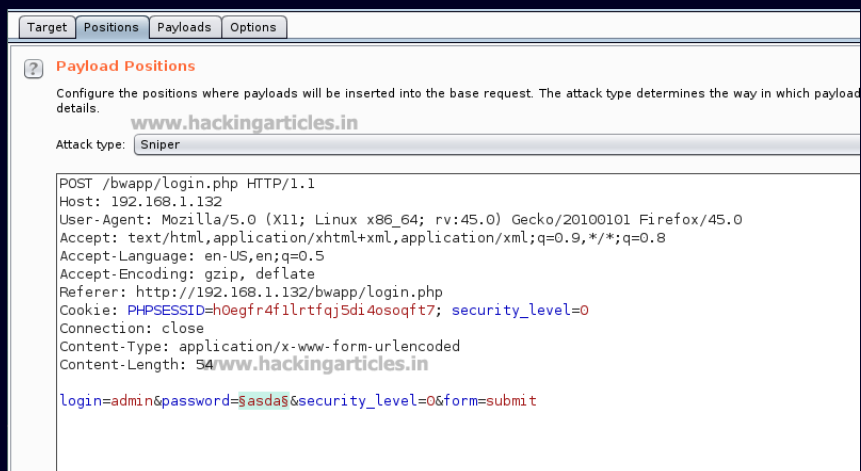
4. برای تعیین موقعیت حمله:

- دکمه **Clear** در سمت راست پنجره را فشار دهید.
- فیلد مورد نظر برای حمله (یعنی فیلد رمز عبور) را انتخاب کرده و دکمه **Add** را کلیک کنید.

5. نوع حمله (**Attack type**) را انتخاب کنید (مثلاً **Sniper**).

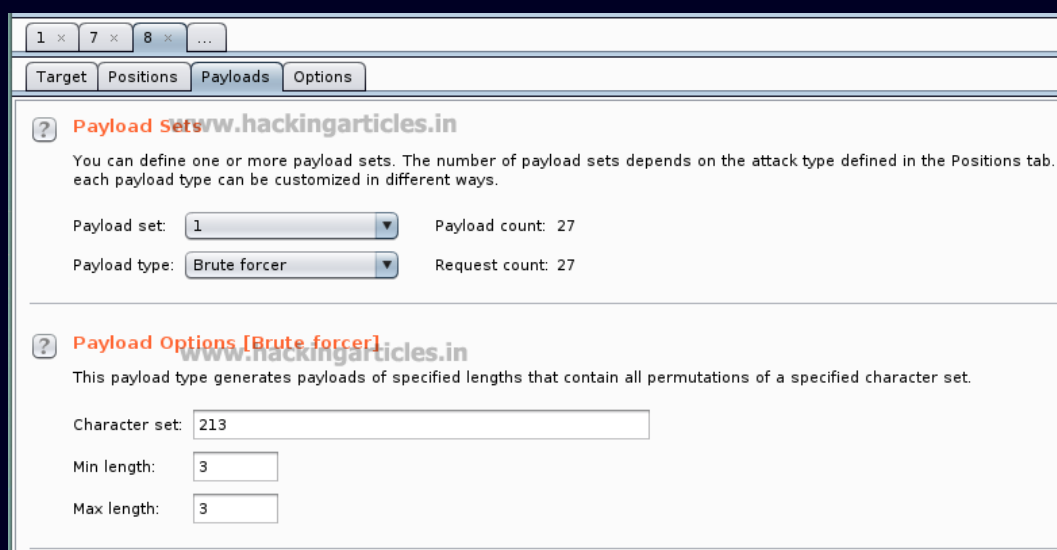


6. همانطور که در تصویر زیر مشاهده می‌کنید، ما فقط رمز عبور را انتخاب کرده‌ایم، که به این معنی است فقط به یک پیلود برای رمز عبور نیاز داریم.

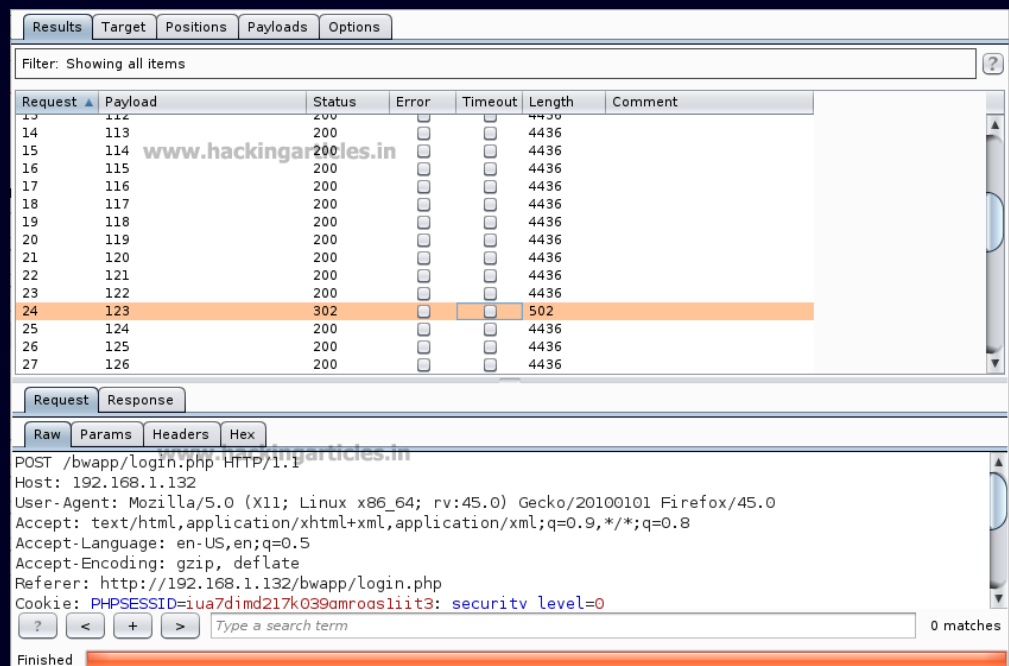


Configuring Payloads and Starting the Attack

سپس نوع **Payload type** را به صورت **Brute Forcer** انتخاب کنید. در بخش **Character set** می‌توانید هر نوع کاراکتری وارد کنید (مثلاً **213** را وارد کرده‌ایم). همچنین **Min length** و **Max length** را روی **3** تنظیم کرده‌ایم (همانطور که در تصویر نشان داده شده است). می‌توانید این مقادیر را بر اساس نیاز خود به صورت دستی تنظیم کنید. از منوی **Intruder** گزینه **Start Attack** را انتخاب کنید.



حالا **Burp Suite** کار خود را انجام می‌دهد، رمز عبور را مطابقت داده و رمز عبور صحیح را پیدا می‌کند. به محض یافتن مقدار صحیح، مقدار **length** (طول) تغییر می‌کند، همانطور که نشان داده شده است.



Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
13	112	200	☐	☐	4436	
14	113	200	☐	☐	4436	
15	114	200	☐	☐	4436	
16	115	200	☐	☐	4436	
17	116	200	☐	☐	4436	
18	117	200	☐	☐	4436	
19	118	200	☐	☐	4436	
20	119	200	☐	☐	4436	
21	120	200	☐	☐	4436	
22	121	200	☐	☐	4436	
23	122	200	☐	☐	4436	
24	123	302	☐	☐	502	
25	124	200	☐	☐	4436	
26	125	200	☐	☐	4436	
27	126	200	☐	☐	4436	

Request Response

Raw Params Headers Hex

POST /bwapp/login.php HTTP/1.1
Host: 192.168.1.132
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.132/bwapp/login.php
Cookie: PHPSESSID=iua7dimd217k039amroasliit3: security level=0

0 matches

Finished

